Builder's Day October 26 · SF Get tickets →

KEY TERMS

A short summary of the clauses most readers want up front. The full legal text below is the agreement itself.

Liability cap	$250,000 (see Sections VI and VIII of the agreement below).
Breach notice	Prisma notifies you without unreasonable delay, in no case later than 15 business days.
Individual requests	Prisma forwards access, amendment and accounting requests to you within 5 days.
Term	Coterminous with your Services Agreement; Company may terminate for Prisma's uncured material breach.
On termination	Prisma returns or destroys the PHI it holds. Where that is infeasible, these protections continue to apply.
How to request it	Available on the Business plan. Read or download the BAA, sign up for Prisma and upgrade your workspace to Business, then email compliance@prisma.io from your account email with your company and signatory details.

✓ Plain English summaries are for convenience only. The legal text governs.

I. Preamble

This HIPAA Business Associate Agreement (“HIPAA Agreement”), effective as of

_____("Effective Date"), is made and entered into by and between

_____. ("Company") and Prisma Data, Inc. ("Business Associate"). This HIPAA Agreement, which supersedes any previous business associate agreement between the parties, amends, supplements, and is made a part of the _____ Agreement, dated _____, by and between Company and Business Associate, as the same may be amended from time to time (the "Services Agreement").

II. Recitals

A. In connection with Business Associate providing services to Company pursuant to the Services Agreement, Business Associate may, on behalf of Company, create, receive, maintain, or transmit certain Protected Health Information ("PHI") as defined below.

B. Company and Business Associate intend to protect the privacy and provide for the security of PHI in compliance with the Health Insurance Portability and Accountability Act of 1996, Subtitle D of the Health Information Technology for Economic and Clinical Health Act of 2009 ("HITECH"), and the regulations and other guidance promulgated under both laws by the U.S. Department of Health and Human Services (collectively, "HIPAA"), as well as other applicable federal and state laws.

C. The purpose of this HIPAA Agreement is to satisfy certain standards and requirements of HIPAA including, but not limited to, 45 C.F.R. §§ 164.308(b), 164.314(a), 164.502(e), and 164.504(e).

D. This HIPAA Agreement shall be applicable only in the event that (1) Company meets, with respect to a covered entity (as that term is defined at 45 C.F.R. § 160.103), the definition of "business associate" set forth in 45 C.F.R. § 160.103; and (2) Business Associate meets, with respect to Company, the definitions of a subcontractor and business associate set forth in 45 C.F.R. § 160.103.

In consideration of the mutual promises below and the exchange of information pursuant to this HIPAA Agreement, the parties agree as follows:

III. Definitions

A. "Covered Entity" shall mean a covered entity, as that term is defined in 45 C.F.R. § 160.103, with respect to whom Company meets the definition of a business associate set forth in 45 C.F.R. § 160.103.

B. "ePHI" shall have the meaning given to the term "electronic protected health information" at 45 C.F.R. § 160.103, as applied to the information created, received, maintained, or transmitted by Business Associate from or on behalf of Company.

C. "Individual" shall have the meaning given to such term at 45 C.F.R. § 160.103, and shall include a person who qualifies as a personal representative in accordance with 45 C.F.R. § 164.502(g).

D. "Privacy Rule" shall mean the Standards for Privacy of Individually Identifiable Health Information at 45 C.F.R. Part 160 and Part 164, Subparts A and E, as amended.

E. "Protected Health Information" or "PHI" shall have the meaning given to the term "protected health information" at 45 C.F.R. § 160.103, as applied to the information created, received, maintained, or transmitted by Business Associate from or on behalf of Company.

F. "Reportable Event" means any (1) use or disclosure of PHI not provided for by this HIPAA Agreement; (2) Security Incident; (3) Breach of Unsecured PHI; or (4) any data incident involving PHI for which data breach notification is required under applicable foreign, federal, or state law.

G. "Secretary" shall mean the Secretary of the U.S. Department of Health and Human Services or his or her designee.

H. "Security Rule" shall mean the Security Standards for the Protection of Electronic Protected Health Information at 45 C.F.R. Part 160 and Part 164, Subparts A and C, as amended.

I. "Subcontractor" shall have the meaning given to the term "subcontractor" at 45 C.F.R. § 160.103.

J. "Unsecured PHI" shall have the meaning given to the term "unsecured protected health information" at 45 C.F.R. § 164.402, as applied to the information created, received, maintained, or transmitted by Business Associate from or on behalf of Company.

K. Any other capitalized terms used, but not otherwise defined, in this HIPAA Agreement shall have the same meaning as those terms in HIPAA. Any inconsistency in the definition of a term shall be resolved in favor of a meaning that permits compliance with HIPAA.

IV. Permitted Uses and Disclosures of PHI

Except as otherwise limited in this HIPAA Agreement or the Services Agreement, Business Associate may do any or all of the following:

A. Use or Disclosure Under the Services Agreement. Use or disclose PHI to perform functions, activities, or services for, or on behalf of Company, to the extent permitted in the Services Agreement, provided that such use or disclosure would not violate the Privacy Rule or any applicable state law if done by Company. Notwithstanding the above, Business Associate may use and disclose PHI for the purposes identified in paragraphs (B), (C), and (E) of this Section IV.

B. Use for Administration or Legal Responsibilities. Use PHI, but only to the minimum extent necessary, for the proper management and administration of Business Associate or to carry out the legal responsibilities of Business Associate.

C. Disclosure for Administration or Legal Responsibilities. Disclose PHI, but only to the minimum extent necessary, for the proper management and administration of Business Associate or to carry out the legal responsibilities of Business Associate, provided that:

(1) The disclosures are Required by Law; or

(2) Business Associate obtains reasonable assurances from the third party to whom the PHI is disclosed that such information shall remain confidential and shall be used or further disclosed only as Required By Law or for the purpose for which it was disclosed to the person (which purpose must be consistent with the limitations imposed upon Business Associate pursuant to this HIPAA Agreement), and such person agrees to promptly notify Business Associate of any instance of which it is aware in which the confidentiality of the information has been breached.

D. Use for Reporting of Violations. Use PHI to report violations of law to appropriate federal, state, and local authorities, consistent with 45 C.F.R. § 164.502(j).

E. Use for Data Aggregation Services. Use PHI to provide Data Aggregation services relating to the health care operations of a Covered Entity, as permitted by 45 C.F.R. §164.504(e)(2)(i)(B), but only if specifically requested by Company on behalf of a Covered Entity in writing.

v. Obligations and Activities of Business Associate

A. Limited by Agreement and Law. Business Associate may not use or disclose PHI other than as permitted or required by this HIPAA Agreement and the Services Agreement or as Required by Law.

B. Compliance with HIPAA. To the extent that Business Associate, pursuant to this HIPAA Agreement or the Services Agreement, is responsible for carrying out an obligation of Company under HIPAA, Business Associate shall comply with the requirements of HIPAA that apply to Company in the performance of such obligation.

C. Appropriate Safeguards. Business Associate shall use appropriate safeguards and, where applicable, comply with the Security Rule with respect to ePHI, to prevent use, loss, modification, destruction, acquisition, or disclosure of, or access to, PHI other than as provided for by this HIPAA Agreement and the Services Agreement. Business Associate shall maintain a comprehensive written information privacy and security program that includes administrative, technical, and physical safeguards appropriate to the size and complexity of Business Associate's operations and the nature and scope of its activities.

D. Reportable Events.

(1) Business Associate shall report to Company any Reportable Event of which it becomes aware. All such reports shall be made without unreasonable delay and in no case later than fifteen (15) business days after Business Associate's discovery of a Reportable Event. If additional time is needed for a thorough investigation, the Business Associate shall notify the Company and provide a reasonable timeline for a complete report.

(2) The notification required hereunder shall include, to the extent possible: (i) the identification of each Individual whose PHI has been, or is reasonably believed by Business Associate to have been, accessed, acquired, used, lost, modified, destroyed, or disclosed during the Reportable Event; (ii) a brief description of what happened, including the date of the Reportable Event and the date of the discovery of the Reportable Event; (iii) a description of the types of PHI involved; (iv) any steps Individuals should take to protect themselves from potential harm resulting from the Reportable Event; (v) a brief description of what Business Associate is doing to investigate, remediate, and respond to the Reportable Event, mitigate harm to Individuals, and protect against further Reportable Events; and (vi) such other information that is reasonably available to

Business Associate that Company would reasonably be expected to need to fulfill its notification obligations with respect thereto. Business Associate shall supplement its initial notification as additional information is obtained.

(3) Business Associate shall cooperate with Company in investigating a Reportable Event and assist Company in determining whether there are any notification obligations under applicable law related thereto.

(4) Business Associate shall mitigate, to the extent practicable, any harmful effect that is known to Business Associate of a Reportable Event.

(5) Business Associate shall bear the costs reasonably incurred by Company in responding to a Reportable Event, which shall include, without limitation: (i) the reasonable cost of preparing and distributing notifications to affected Individuals and, if applicable, the media; (ii) the reasonable cost of providing notice to government agencies, credit bureaus, and/or other required entities; (iii) the reasonable cost of providing affected Individuals with credit monitoring services; (iv) the reasonable cost of call center support for such affected Individuals; and (v) any other reasonable costs, including but not limited to attorneys' fees, incurred in investigating, responding to, and mitigating the harmful effects of such event. Notwithstanding the foregoing, Business Associate's total financial liability for such costs shall be limited to $250,000.

(6) The parties acknowledge and agree that this Section V.D constitutes notice by Business Associate to Company of the ongoing existence and occurrence of attempted but unsuccessful Security Incidents that do not result in unauthorized access to, or use, loss, modification, destruction, or disclosure of, PHI, such as pings and other broadcast attacks on Business Associate's firewall, port scans, unsuccessful log-on attempts, unsuccessful denial of service attacks, or any combination thereof. The parties further acknowledge that Business Associate shall only provide additional notice of any such unsuccessful Security Incident to Company upon request.

E. Subcontractors. If Business Associate discloses PHI to a Subcontractor or allows a Subcontractor to create, receive, maintain, or transmit PHI on its behalf, Business Associate must, in accordance with 45 C.F.R. §§ 164.308(b)(2) and 164.502(e)(1)(ii), ensure that such Subcontractor agrees to the same restrictions, conditions, and requirements that apply to Business Associate with respect to such information by entering into a written arrangement with Subcontractor that complies with 45 C.F.R. §§ 164.314(a) and 164.504(e). If Business Associate becomes aware of a pattern of activity or practice of a Subcontractor that would constitute a material breach or violation of the written agreement between Business Associate and

Subcontractor, Business Associate shall take reasonable steps to cure such breach or end the violation, as applicable, or terminate such written agreement with such Subcontractor.

F. Access to PHI. Business Associate shall provide access to PHI maintained in a Designated Record Set to Company or, as directed by Company, to an Individual, in accordance with 45 C.F.R. § 164.524 and in the time and manner specified by the Company. In the event an Individual requests access to PHI maintained in a Designated Record Set directly from Business Associate, Business Associate shall, within five (5) days of receipt of such request, forward such request to Company.

G. Amendment of PHI. Business Associate shall make amendments to PHI maintained in a Designated Record Set that Company directs in accordance with 45 C.F.R. § 164.526 and in the time and manner specified by Company. In the event an Individual requests an amendment to PHI maintained in a Designated Record Set directly from Business Associate, Business Associate shall, within five (5) days of receipt of such request, forward such request to Company. Company or the applicable Covered Entity, as appropriate, shall be responsible for making all determinations regarding amendments to PHI, and Business Associate will make no such determinations.

H. Documentation of Disclosures. Business Associate shall maintain a log that documents all disclosures of PHI and information related to such disclosures such that a Covered Entity can respond to a request by an Individual for an account of disclosures of PHI in accordance with 45 C.F.R. § 164.528 and Section 13405(c) of HITECH and any regulations promulgated thereunder. Business Associate shall provide the log to Company upon request.

I. Accounting of Disclosures. Business Associate shall provide Company such information collected in accordance with Section V.H of this HIPAA Agreement in a time and manner specified by Company to permit Company and a Covered Entity to respond to a request by an Individual for an accounting of disclosures in accordance with 45 C.F.R. § 164.528. Business Associate shall provide such information directly to an Individual upon the direction of Company. In the event an Individual requests an accounting of disclosures directly from Business Associate, Business Associate shall, within five (5) days of receipt of such request, forward such request to Company.

J. Governmental Access to Records. Business Associate shall make its internal policies, practices, books, and records relating to the use and disclosure of PHI available to the Secretary for purposes of determining compliance with HIPAA.

K. Minimum Necessary. Business Associate agrees that, to the extent practicable, it shall only request, use and disclose PHI in the form of a Limited Data Set (as defined

in 45 C.F.R. § 164.514(e)(2)), and that in all other cases it shall only request, use, or disclose the minimum necessary amount of PHI necessary to accomplish the purposes of the request, use, or disclosure.

L. Documentation. All documentation that is required by this HIPAA Agreement and HIPAA shall be retained by Business Associate for six (6) years from the date of creation or the date when it was last in effect, whichever is later. Business Associate shall ensure that such documentation is securely maintained to prevent unauthorized access, in compliance with

HIPAA requirements. Business Associate shall have the right to destroy such documentation after the six-year period, provided that it is no longer required for legal or regulatory purposes.

M. Prohibition on Sale of PHI and Marketing. Business Associate shall neither sell PHI, nor use and disclose PHI in connection with marketing unless requested in writing to do so by Company and such sale or marketing is permitted under HIPAA.

N. De-Identified Information. Business Associate is not permitted to de-identify PHI and use it for its own purposes, unless expressly permitted by Company in writing. In the event such permission is granted, Business Associate shall ensure that the de-identification process complies with 45 C.F.R. § 164.514.

O. Offshoring. Business Associate shall obtain Company's written consent in advance of transmitting, disclosing, or maintaining PHI (whether by Business Associate or any person/entity engaged by Business Associate) in either of the following: (i) a location outside of the United States; or (ii) by or to a person outside the United States. Such consent shall not be unreasonably withheld, provided that Business Associate can demonstrate that appropriate safeguards are in place to protect PHI in compliance with HIPAA.

VI. Indemnification

Business Associate shall indemnify, defend, and hold harmless Company and each of Company's affiliates, fiduciaries, officers, employees, and agents, from and against any claim or demand, damage, cause of action, liability, loss, cost, or expense, including reasonable attorneys' fees, resulting from, arising out of, or relating to: (1) any breach by Business Associate or any of its affiliates, directors, officers, employees, agents, Subcontractors, or successors of the terms of this HIPAA Agreement; (2) any negligence or willful misconduct of Business Associate or any of its affiliates, directors, officers, employees, agents, Subcontractors, or successors in the performance of

Business Associate's duties under this HIPAA Agreement; or (3) any Reportable Event caused by Business Associate or any of its affiliates, directors, officers, employees, agents, Subcontractors, or successors. Business Associate further agrees to assist and defend Company in any investigation, litigation, adjudication, arbitration, or proceeding of any kind, whether brought by the Secretary, an Individual, or any other person or entity, that may result or arise from any breach of the terms of this HIPAA Agreement. However, the total liability of Business Associate under this indemnification provision shall not exceed $250,000 in the aggregate.

VII. Term and Termination

A. Term. The term of this HIPAA Agreement shall commence as of the Effective Date, be coterminous with the Services Agreement, and continue in full force and effect from year to year, but shall terminate as of the earliest occurrence of any of the following:

(1) The Services Agreement is terminated;

(2) This HIPAA Agreement is terminated for cause as described in Section VII.B below;

(3) The parties mutually agree to terminate this HIPAA Agreement; or

(4) This HIPAA Agreement is terminated under applicable federal, state, or local law.

B. Termination for Cause. Upon Company's determination of a material breach by Business Associate of this HIPAA Agreement, Company shall notify Business Associate of its knowledge of such breach and shall have the right but not the duty to terminate this HIPAA Agreement and the Services Agreement after providing Business Associate with a 30-day period to cure the breach or end the violation, unless immediate termination is required by law. Such termination shall take effect within a reasonable period of time after written notice from Company to Business Associate that this HIPAA Agreement is being terminated, absent extraordinary circumstances; provided, however, that the obligations imposed on Business Associate pursuant to this HIPAA Agreement shall continue until the date when all PHI held by Business Associate is destroyed, returned to Company, or, if it is infeasible to return or destroy PHI, protections are extended to such information in accordance with Section VII.C below. In lieu of immediate termination, Company may, but does not have the duty to, provide Business Associate with an opportunity to cure the breach or end the violation within thirty (30) days.

C. Effect of Termination

(1) Upon termination of this HIPAA Agreement for any reason, Business Associate shall return or destroy all PHI that Business Associate still maintains in any form. Business Associate shall retain no copies of such PHI.

(2) If return or destruction of any or all PHI is not feasible, Business Associate shall:

(i) Notify Company of the conditions that make return or destruction of all PHI not feasible;

(ii) Retain only that PHI for which is necessary for Business Associate to continue its proper management and administration or to carry out its legal responsibilities;

(iii) Return to Company, or at Company's direction, or destroy the remaining PHI that Business Associate still maintains in any form;

(iv) Extend the protections and obligations of this HIPAA Agreement to any retained PHI for as long as Business Associate retains the PHI;

(v) Not use or disclose the PHI retained by Business Associate other than for the purposes for which such PHI was retained and subject to the same conditions set forth in Sections IV.B and IV.C of this HIPAA Agreement that applied prior to termination; and

(vi) Return to Company or, at Company's direction, destroy the PHI retained by Business Associate when it is no longer needed by Business Associate for its proper management and administration or to carry out its legal responsibilities.

(3) These provisions of this Section VII.C shall apply to PHI that is in the possession of Subcontractors or agents of Business Associate.

(4) Upon request by Company, Business Associate shall certify to Company that it has destroyed or returned all PHI.

(5) Any PHI that Business Associate destroys shall be destroyed in accordance with HIPAA.

VIII. Miscellaneous

A. Regulatory References. A reference in this HIPAA Agreement to a section in HIPAA means the section as in effect or as amended at the time this HIPAA Agreement is executed or amended.

B. Amendment; No Waiver. Upon the effective date of any federal statute amending or expanding HIPAA, any guidance or temporary, interim final or final regulations promulgated under HIPAA, or under any federal statute amending or expanding HIPAA (collectively, the "HIPAA Regulations") that are applicable to this HIPAA Agreement or any amendments to the HIPAA Regulations, this HIPAA Agreement shall be automatically amended, such that the obligations imposed on Company and Business Associate shall remain in compliance with such requirements, unless the parties agree otherwise by mutual consent. The parties shall take all necessary action to expressly reflect such automatic amendments to this HIPAA Agreement from time to time. Except as provided otherwise in this Section VIII.B, no waiver, change, modification, or amendment of any provision of this HIPAA Agreement shall be made unless it is in writing and is signed by the parties hereto. The failure of either party at any time to insist upon strict performance of any condition, promise, agreement, or understanding set forth herein shall not be construed as a waiver or relinquishment of the right to insist upon strict performance of the same condition, promise, agreement, or understanding at a future time.

C. Survival. All of the respective rights and obligations of Business Associate under Section V.L (Documentation), Section VI (Indemnification) and Section VII.C (Effect of Termination) of this HIPAA Agreement shall survive the termination of this HIPAA Agreement and the Services Agreement.

D. Interpretation. Any ambiguity in this HIPAA Agreement shall be resolved in favor of a meaning that permits compliance with HIPAA. The titles and headings set forth at the beginning of each section hereof are inserted for convenience of reference only and shall in no way be construed as a part of this HIPAA Agreement or as a limitation on the scope of the particular provision to which it refers. In the event of an inconsistency between the provisions of this HIPAA Agreement and the mandatory terms of HIPAA, as may be expressly amended from time-to-time by the Secretary, or as a result of interpretations by the Secretary, a court, or another regulatory agency with authority over the parties, the interpretation of the Secretary, such court, or regulatory agency shall prevail.

E. Entire Agreement; Effect on the Services Agreement. This HIPAA Agreement, together with the Services Agreement and any statements of work, exhibits, or other addenda thereto, sets forth the entire understanding between the parties and supersedes any previous or contemporaneous understandings, commitments, representations, warranties, or agreements, written or oral, regarding the subject

matter hereof. No representations, agreements, or understandings of any kind, either written or oral, except as set forth or incorporated by reference

into this HIPAA Agreement or the Services Agreement, have been relied upon in entering into this HIPAA Agreement, nor shall any such representations, agreements, or understandings be binding upon the parties unless expressly contained herein or therein. Notwithstanding any provision to the contrary in this HIPAA Agreement or the Services Agreement, to the extent that any term in this HIPAA Agreement is directly contradictory to a term in the Services Agreement, the term in this HIPAA Agreement shall supersede such contradictory term to the extent necessary to permit compliance with HIPAA.

F. Relationship of Parties. The parties to this HIPAA Agreement are independent contractors. None of the provisions of this HIPAA Agreement are intended to create, nor shall they be interpreted or construed to create, any relationship between Company and Business Associate other than that of independent contractors. Except as otherwise expressly set forth herein, neither party, nor any of its representatives, shall be deemed to be the agent, employee, or representative of the other party.

G. No Third Party Beneficiaries. This HIPAA Agreement is between the parties hereto. Nothing express or implied in this HIPAA Agreement is intended to confer, nor shall anything herein confer, any rights, remedies, obligations, or liabilities whatsoever upon any person other than Covered Entity and Business Associate and any respective successors and assigns.

H. Invalid or Unenforceable Provision. The provisions of this HIPAA Agreement shall be severable. The invalidity or unenforceability of any particular provision or portion of such provision of this HIPAA Agreement shall be construed, in all respects, as if such invalid or unenforceable provision or portion of such provision had been omitted, and shall not affect the validity and enforceability of the other provisions hereof or portions of that provision.

I. Nonassignability; Benefits and Burdens. The parties' rights and obligations with respect to the assignment of this HIPAA Agreement shall be subject to the assignment provision set forth in the Services Agreement. In the event that the Services Agreement does not contain an agreement provision, neither party may assign its rights, or delegate its duties or obligations, under this HIPAA Agreement without the prior written consent of the other party, which consent shall not be unreasonably withheld. This HIPAA Agreement shall be binding upon, and shall inure to the benefit of, the parties hereto and their respective successors.

J. Applicable Law. This HIPAA Agreement shall be construed, administered, and governed by the governing law set forth in the Services Agreement, except to the

extent preempted by applicable federal law. In the event that the Services Agreement does not identify the governing law, this HIPAA Agreement shall be construed, administered, and governed under the laws of the State of California, except to the extent preempted by applicable federal law.

K. Notices. All notices hereunder shall be in writing, and either delivered by hand, or sent by mail, or delivered in such other manner as the parties may agree upon, to the following:

To Company: _____ Attention: _____ _____ _____

To Business Associate: Prisma Data, Inc._____ Attention: _____ _____ Prisma Data, Inc., 38350 Fremont Blvd #203, Fremont, CA 94536

Each party reserves the right to change address for receiving notice during the term of this HIPAA Agreement upon written notice to the other parties.

L. Counterparts. This HIPAA Agreement may be executed in separate counterparts, none of which need contain the signatures of both parties, and each of which, when so executed, shall be deemed to be an original, and such counterparts shall together constitute and be one and the same instrument.

M. Force Majeure: Neither party shall be liable for any failure or delay in performing its obligations under this HIPAA Agreement or the Services Agreement if such failure or delay is due to circumstances beyond its reasonable control, including but not limited to acts of God, war, terrorism, labor strikes, natural disasters, or pandemics. The affected party shall notify the other party as soon as practicable and shall use reasonable efforts to resume performance as soon as possible.

Limitation of Liability: Except with respect to claims arising from gross negligence, willful misconduct, or indemnification obligations under this Agreement, Business Associate's total liability for all claims arising out of or relating to this HIPAA Agreement or the Services Agreement shall not exceed $250,000. In no event shall Business Associate be liable for any indirect, incidental, special, consequential, or punitive damages, even if advised of the possibility of such damages

How to request and execute your BAA

The real agreement is countersigned by an authorised Prisma Data, Inc. signatory after you request it. The marketing page does not take requests.

1. Read the BAA above or and share it with your legal and compliance team.
2. Sign up for Prisma and upgrade your workspace to the Business plan.
3. Email compliance@prisma.io from your account email with your company name, address, workspace, and signatory name and email.
4. Prisma sends the agreement for e-signature.

Get started

See how Prisma Postgres fits a healthcare workload on the HIPAA overview.